

Vendor Risk Management on a Budget: Free Tools, A Bad Attitude, and Everything Vendors Forget to Mention

Chris Green

Director of Governance, Risk, & Compliance

Chris Green

Director of Governance, Risk, & Compliance

CISSP, CISA, CRISC, QSA/PCIP, OSCP, CMMC RP

- **13 years in Information Security**
- **Help Build and Improve Cybersecurity and GRC Programs**
 - Security Program Development
 - Policy Documentation
 - Compliance Assessments
 - Risk Management
 - Penetration Testing
 - vCISO / GRC Consulting

Structured Practices

Governance, Risk, & Compliance



Cybersecurity



Cloud Services



Data Center Solutions



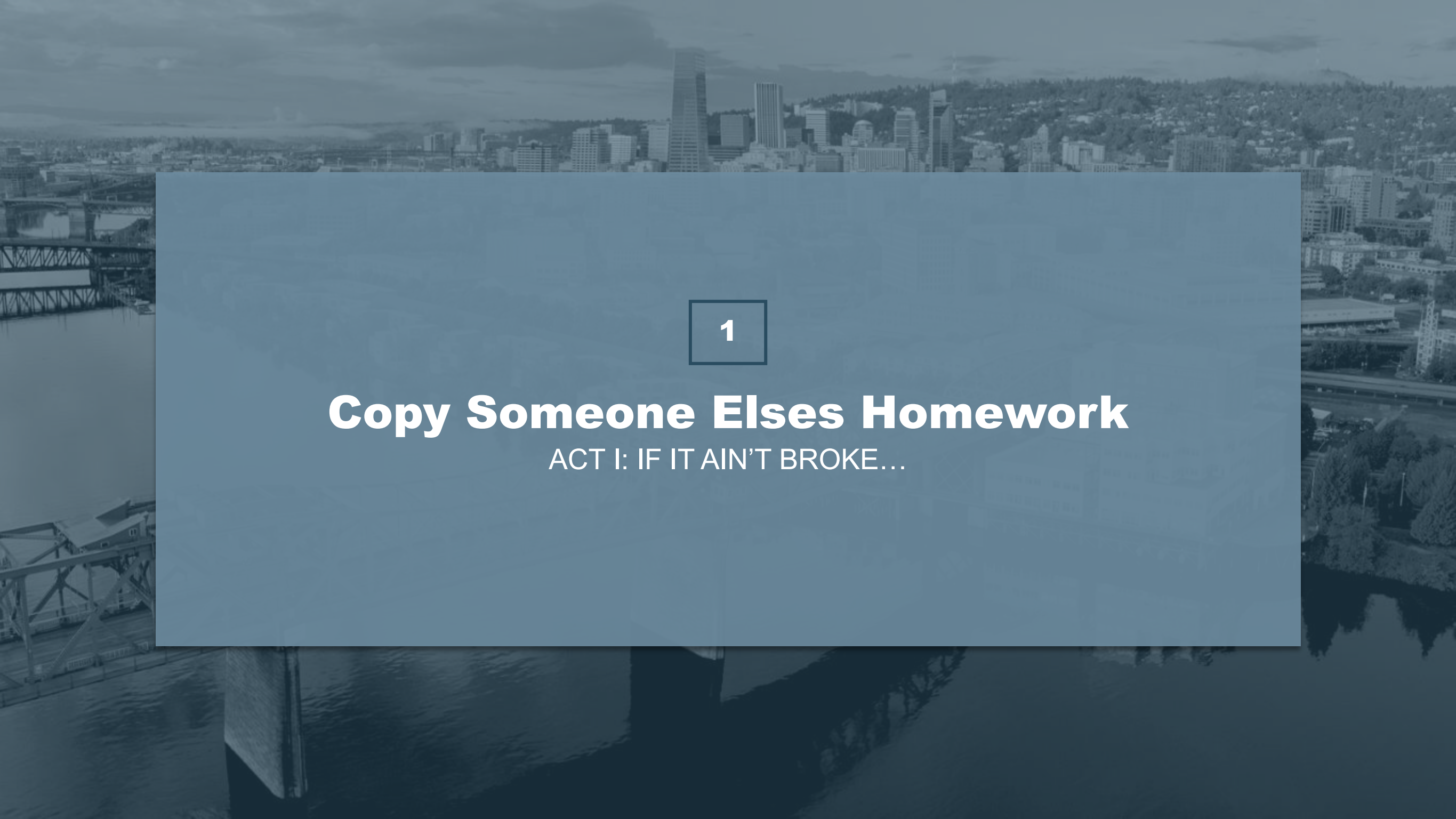
Networking



Unified Communications & Collaboration



Secure Managed Services



1

Copy Someone Elses Homework

ACT I: IF IT AIN'T BROKE...

CSA STAR Registry | CAIQ!

CSA = Cloud Security Alliance

STAR = Security, Trust, Assurance, and Risk

CAIQ = Consensus Assessments Initiative Questionnaire

Cloud and SaaS security self-assessments
No account, no paywall

- Level 1 is a free self-assessment against the CAIQ
- Level 2 adds third party certification
- Level 3 adds continuous attestation.

Your five-hour questionnaire may already be a two-minute lookup

Search by vendor name at <https://cloudsecurityalliance.org/star/registry>



Digging for CAIQs



Salesforce.com, Inc.

Listed Since: 2016-03-13



EU Cloud CoC 

AI CAIQ 

CAIQ 



Slack

Where Work Happens When your team needs to kick off a project, hire a new employee, deploy some code, review a sales contract, finalize next year's...

Listed Since: 2018-03-22



CAIQ 

ISO/IEC 42001 

Digging for CAIQs



Microsoft

Microsoft Azure is a cloud computing platform for building, deploying and managing applications through a global network of Microsoft and third-party mana...

Listed Since: 2016-04-06



AI CAIQ 

CAIQ 

EU Cloud 



Certification 

ISO/IEC
42001 



[View Listing](#)

CAIQ and the Cloud Controls Matrix

CAIQ ~140 yes/no questions mapped directly onto the CCM

The CCM maps to **ISO 27001**, **NIST SP 800-53**, **PCI DSS**, and **SOC 2**.
One vendor document, many frameworks.

Download the CCM spreadsheet free and use it as your own control mapping backbone.

<https://cloudsecurityalliance.org/research/cloud-controls-matrix/>

BONUS!

When an auditor asks how your vendor controls map to their framework, the CCM crosswalk answers it without you building a mapping from scratch.

HECVAT 4 – Higher Education Community Vendor Assessment Toolkit

- Many education vendors already have a completed HECVAT and will hand it over if asked.
- <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit>

K-12 CVAT

- Useful for student data privacy reviews where districts are assessing with no security staff
- <https://www.cosn.org/tools-and-resources/resource/k-12cvat/>

SIG and SIG Lite

Shared Assessments' Standardized Information Gathering questionnaire.

The enterprise default.

- Widely completed by mid-size and large vendors, because their other customers already demanded it.

SIG Lite is the scoped down version, appropriate for lower tier vendors or a fast first pass.

Reading a vendor's completed copy is free

- Ask them: Do you already have a completed CAIQ, HECVAT, or SIG report you can share?

Trust Centers

Vendor published, self service portals with SOC 2 reports, ISO certificates, pen test summaries, and more.

Common trust center hosts:

- SafeBase/Drata
- Vanta
- Conveyor
- TrustCloud
- Orbix

The vendor pays thousands a year for the platform. Reading it is free

- **Five minutes in a trust center will answer a lot of questions**

Hunting for a Trust Center

Try

- `trust.vendor.tld`
- `security.vendor.tld`
- `vendor.tld/trust`
- `vendor.tld/security`

Also platform subdomains

- `vendor.safebase.io`
- `trust.vanta.com/vendor`
- Etc.



Hunting for a Trust Center

Brute force it!

```
$ d=salesforce.com; for s in trust trustcenter trust-center  
safe security privacy compliance portal vendor security-  
portal trust-portal compliance-portal safeguard trusthub  
assurance risk secure shield privacyportal securityhub  
compliancehub safebase vendor-portal grc audit certifications  
reports soc securityportal complianceportal; do r=$(curl -sLo  
/dev/null -w "%{http_code}|%{url_effective}" -L --connect-  
timeout 3 --max-time 5 "https://$s.$d" 2>/dev/null);  
c="${r%%|*}"; u="${r##*|}"; case "$c" in 2*|401) printf  
"\033[1;32m[FOUND] %s (%s) -> %s\033[0m\n" "$s.$d" "$c"  
"$u";; 000) printf "  [---] %s\n" "$s.$d";; *) printf " [%s]  
%s\n" "$c" "$s.$d";; esac; done
```

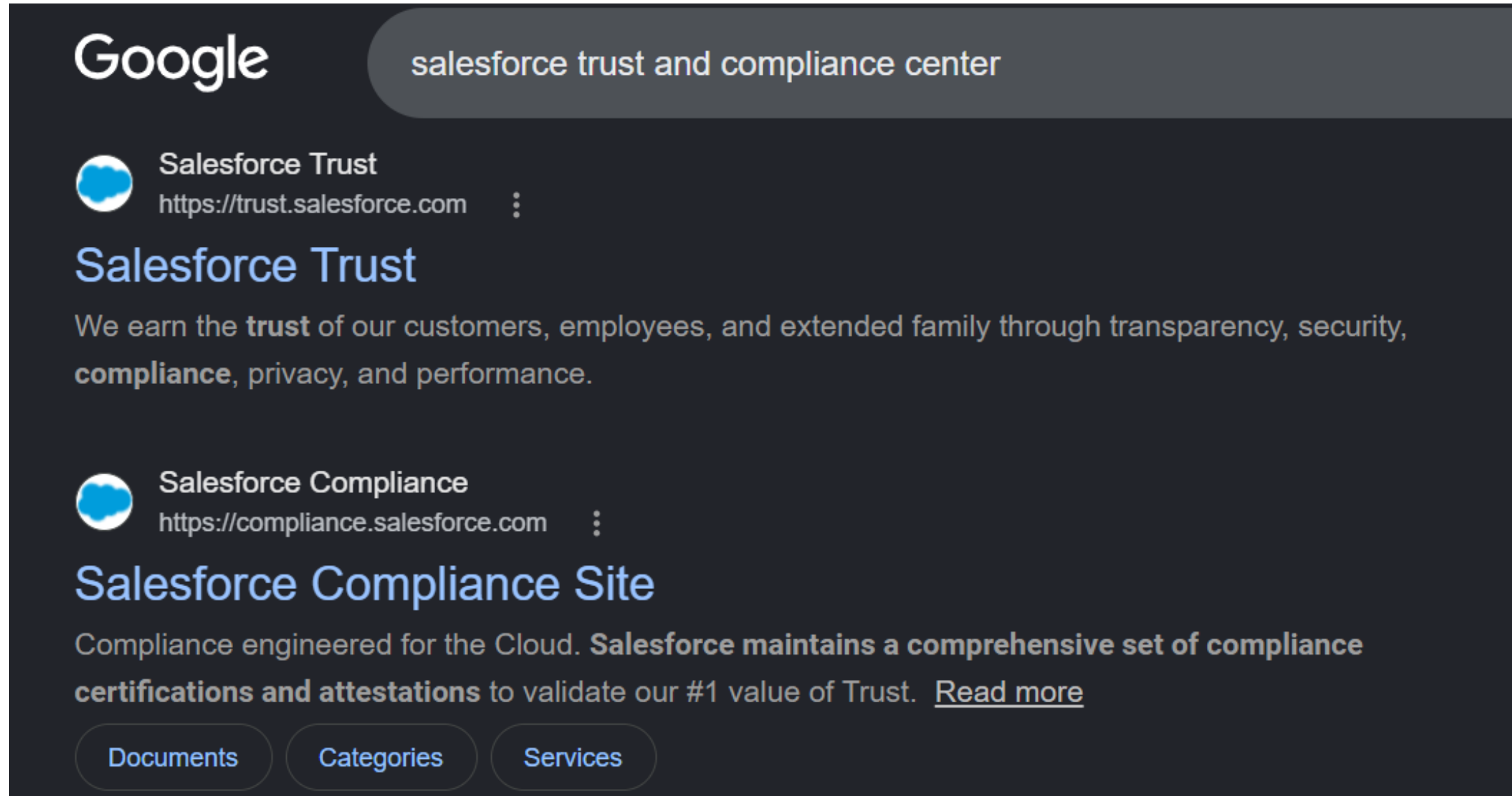
Hunting for a Trust Center

Brute force it!

```
> TPRM-Party:~ $ d=salesforce.com; for s in trust trustcenter trust-center safe
security privacy compliance portal vendor security-portal trust-portal complia
nce-portal safeguard trusthub assurance risk secure shield privacyportal securit
yhub compliancehub safebase vendor-portal grc audit certifications reports soc s
ecurityportal complianceportal; do r=$(curl -sLo /dev/null -w "%{http_code}|%{ur
l_effective}" -L --connect-timeout 3 --max-time 5 "https://$s.$d" 2>/dev/null);
c="${r%%|*}"; u="${r##*|}"; case "$c" in 2*|401) printf "\033[1;32m[FOUND] %s (%
s) -> %s\033[0m\n" "$s.$d" "$c" "$u";; 000) printf " [---] %s\n" "$s.$d";; *) p
rintf " [%s] %s\n" "$c" "$s.$d";; esac; done
[FOUND] trust.salesforce.com (200) -> https://trust.salesforce.com/
[---] trustcenter.salesforce.com
[---] trust-center.salesforce.com
[---] safe.salesforce.com
[FOUND] security.salesforce.com (200) -> https://security.salesforce.com/
[---] privacy.salesforce.com
[FOUND] compliance.salesforce.com (200) -> https://compliance.salesforce.com/en
[---] portal.salesforce.com
[---] vendor.salesforce.com
```

Hunting for a Trust Center

Or just Google it



Hunting for a Trust Center



Compliance

Home

Categories

Services

Documents

Search...



Name	Updated On	Infrastructure	Category
Salesforce Enterprise Resilience/BCP Summary	2026-07-23	First party AWS Hyperforce	Resilience, BCP & DR
SOC 1 Report - Corporate Services	2026-06-05	First party AWS Hyperforce	SOC 1
SOC 2 Report - Corporate Services	2026-06-05	First party AWS Hyperforce	SOC 2
Salesforce EU Processor Binding Corporate Rules	2026-05-06	First party AWS Hyperforce	Salesforce BCRs
Salesforce UK Processor Binding Corporate Rules	2026-05-06	First party AWS Hyperforce	Salesforce BCRs
Salesforce Secure Development Lifecycle Overview (JP)	2026-05-01	First party AWS Hyperforce	FAQ's and White Papers
ISO/IEC 27017:2015 Certificate	2026-04-18	First party AWS Hyperforce	ISO 27017
ISO/IEC 27018:2019 Certificate	2026-04-18	First party AWS Hyperforce	ISO 27018
ISO/IEC 27001:2022 Certificate	2026-04-17	First party AWS Hyperforce	ISO 27001

Cloud Provider Compliance Portals

Verify your vendor's hosted platform!

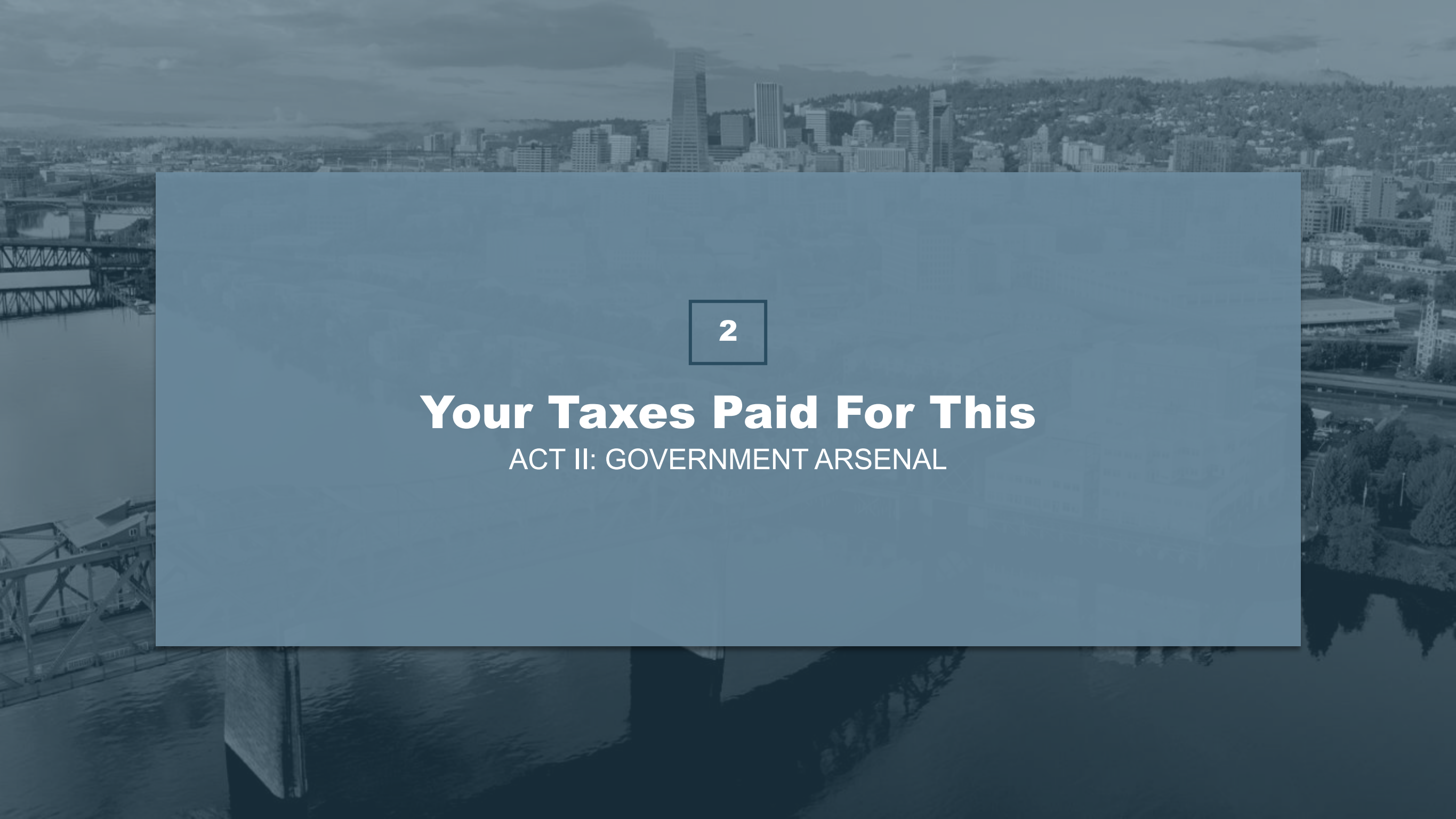
- Amazon / AWS: <https://aws.amazon.com/artifact/>
- Microsoft / Azure: <https://servicetrust.microsoft.com/>
- Google / GCP:
<https://cloud.google.com/security/compliance/compliance-reports-manager>

No need to ask a small SaaS vendor for evidence about datacenter physical security

Covers the infrastructure, not your vendor's application. Know the difference and report this to your auditor

Cloud Provider Compliance Portals

☐	 Microsoft 365 Microservices (Type 1) - SOC 2 Type 1 Report (9-30-2025) ↓	Microsoft 365 Microservices (Type 1) - SOC 2 Type 1 Report (9-30-2025)	2026-08-05
☐	 Azure + Dynamics 365 + Online Services – Public & Government SOC 1 Type II Report (04-01-2025 to 3-31-2026) ↓	This document details audit assessment performed by a third party independent auditor on Azure + Dynamics + Online Services 365 Public & Government systems, design, and o... Show more	2026-07-20
☐	 Microsoft General - Nuance Healthcare Cloud (Multiple Products) - SOC 2 (2026) ↓	SOC 2 report covering the following Nuance products: Clintegrity (CLU and CDE One), DAX)/DAX Copilot, Dragon Professional Anywhere, mPower, PowerScribe One Essentials, P... Show more	2026-07-13
☐	 Microsoft 365 - SOC 1 Type 1 Report (05-15-2026) ↓	Microsoft 365 - SOC 1 Type 1 Report (05-15-2026)	2026-07-09
☐	 Azure + Dynamics 365 + Online Services – Public & Government C5 Report (04-01-2025 to 3-31-2026) ↓	Microsoft Azure and Azure Government Cloud Computing Compliance Criteria Catalogue (C5) Report	2026-07-08

An aerial photograph of a city skyline, likely San Francisco, featuring the Transamerica Pyramid and other skyscrapers. In the foreground, a large bridge spans a body of water, with its reflection visible. The image is overlaid with a semi-transparent blue rectangle containing text.

2

Your Taxes Paid For This

ACT II: GOVERNMENT ARSENAL

Managing Your Supply Chain

National Institute of Standards and Technology – NIST SP 800-161r1

- Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations
- <https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final>

NIST CSF 2.0 and GV.SC

- GV.SC, Cybersecurity Supply Chain Risk Management, carries ten subcategories
- <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

CISA Vendor SCRM Template

- Questionnaire for suppliers
- <https://www.cisa.gov/resources-tools/resources/vendor-supply-chain-risk-management-scrm-template>

FedRAMP and GovRAMP – Already Vetted!

FedRAMP

The federal government's searchable registry of authorized cloud services

- Needed if working with federal entities
- Audited and approved!
- <https://marketplace.fedramp.gov/>

GovRAMP (formerly StateRAMP)

The state and local equivalent, rebranded in 2025

- A free public registry of vendors authorized or progressing against a common state and local standard
- Relevant to state agencies, counties, districts, and public universities
- Authorized product list: <https://govramp.org/program-participants#apl>

KEV, NVD, and EPSS – Vendor Product Checks

KEV = CISA's Known Exploited Vulnerabilities, free list of known exploited vulnerabilities

NVD = National Vulnerability Database, provides CVE details

EPSS = Exploit Prediction Scoring System, probability that a CVE will be exploited, which beats CVSS severity for prioritization

Loop it!

```
$ KEV=https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json  
  
$ curl -s $KEV | jq -r  
' .vulnerabilities[] | select(.vendorProject | test("citrix"; "i")) | "\(.cveID) \(.product) "'
```

KEV, NVD, and EPSS

```
> TPRM-Party:~ $ KEV=https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json  
> TPRM-Party:~ $ curl -s $KEV | jq -r '.vulnerabilities[]|select(.vendorProject|test("citrix";"i"))|"\(.cveID)  
\(.product)"'
```

```
CVE-2026-19490 NetScaler  
CVE-2026-8452 NetScaler ADC and NetScaler Gateway  
CVE-2026-3055 NetScaler  
CVE-2025-7775 NetScaler  
CVE-2024-8068 Session Recording  
CVE-2024-8069 Session Recording  
CVE-2025-5777 NetScaler ADC and Gateway  
CVE-2025-6543 NetScaler ADC and Gateway  
CVE-2023-6549 NetScaler ADC and NetScaler Gateway  
CVE-2023-6548 NetScaler ADC and NetScaler Gateway  
CVE-2023-4966 NetScaler ADC and NetScaler Gateway  
CVE-2023-24489 Content Collaboration  
CVE-2023-3519 NetScaler ADC and NetScaler Gateway  
CVE-2022-27518 Application Delivery Controller (ADC) and Gateway  
CVE-2021-22941 ShareFile  
CVE-2019-12991 SD-WAN and NetScaler  
CVE-2019-12989 SD-WAN and NetScaler  
CVE-2017-6316 NetScaler SD-WAN Enterprise, CloudBridge Virtual WAN, and XenMobile Server  
CVE-2019-13608 StoreFront Server  
CVE-2020-8193 Application Delivery Controller (ADC), Gateway, and SD-WAN WANOP Appliance  
CVE-2020-8195 Application Delivery Controller (ADC), Gateway, and SD-WAN WANOP Appliance
```



3

Now Let's Do Our Own Digging

ACT III: OUTSIDE-IN RECON

Passive Is Legal, Active Needs Permission

We're about to point recon tools at companies that haven't hired us!

GOOD: Passive Collection

Querying third party databases that already hold the data. Certificate transparency logs, Shodan, breach indexes, public registries, WHOIS, archives. You never touch the vendor's infrastructure. This is reading public records.

BAD: Active Interaction

Port scanning, vulnerability scanning, nuclei templates, subdomain brute forcing, credential testing, logging into anything. This sends packets to someone else's systems. Without written authorization this is a CFAA conversation, not a due diligence one.

- ! Never authenticate with creds found in a breach dump, not even to verify
- ! Never purchase leaked data. Free viewing is not the same as funding a criminal market
- ! Document your actions and keep the evidence you collected

Security Ratings, Free Tiers

Security Scorecard

- Free tier lets you see your own rating and monitor a small number of vendors at no cost

Bitsight

- If an existing Bitsight customer invites you as a client, you can view their security ratings on the platform at no cost

Both score external, passive signals only and misattribute shared infrastructure more than people assume

TLS and Header Graders

Qualys SSL Labs: grades TLS configurations

Mozilla Observatory & securityheaders.com: cover HTTP security headers, CSP, HSTS, and related hygiene

Hardenize: gives single-page view including email authentication, SPF, DKIM, and DMARC

! A vendor with no DMARC enforcement is a vendor whose domain can be spoofed.
A supply chain finding you can demonstrate in thirty seconds!

<https://www.ssllabs.com/ssltest/analyze.html?d=scanme.nmap.org>

<https://developer.mozilla.org/en-US/observatory/analyze?host=scanme.nmap.org>

<https://securityheaders.com/?q=scanme.nmap.org&followRedirects=on>

<https://www.hardenize.com/report/scanme.nmap.org>

Install the tools I use in the examples

```
# install go apt - remove default, install latest
sudo rm -rf /usr/local/go && LATEST_GO=$(curl -sSL https://go.dev/VERSION?m=text | head -n1) && curl -sSL "https://go.dev/dl/${LATEST_GO}.linux-
amd64.tar.gz" | sudo tar -xz -C /usr/local && echo "export PATH=\$PATH:/usr/local/go/bin:\$HOME/go/bin" >> ~/.profile && source ~/.profile

# install go brew
brew install go
-----
# install the tools

# apt - Debian/Ubuntu (subfinder, httpx-toolkit, amass are Kali-only packages – see note below)
sudo apt update && sudo apt install -y python3-pip python3-venv python3-dnspython build-essential pipx git curl dnstwist && pipx ensurepath

# apt - Kali (has the extra recon tools in its repos)
sudo apt update && sudo apt install -y python3-pip python3-venv python3-dnspython build-essential pipx git curl dnstwist subfinder httpx-toolkit amass
&& pipx ensurepath

# brew
brew install python3 pipx go git curl amass gitleaks trufflehog && pipx ensurepath

# pipx
pipx install shodan && pipx inject shodan setuptools && pipx install dnstwist && pipx inject dnstwist dnspython && pipx install censys && pipx install
trufflehog

# go install
go install -v github.com/projectdiscovery/subfinder/v2/cmd/subfinder@latest && go install -v github.com/projectdiscovery/httpx/cmd/httpx@latest && go
install -v github.com/owasp-amass/amass/v4/...@master && go install github.com/zricethezav/gitleaks/v8@latest

# curl
curl -sSfL https://raw.githubusercontent.com/trufflesecurity/trufflehog/main/scripts/install.sh | sudo sh -s -- -b /usr/local/bin
```

Search engine for internet connected things.

They scan the internet so you do not have to!

- Free and paid tiers
- Search by org, ASN, certificate, or hostname to find a vendor's exposed services, management interfaces, and forgotten hosts.

Shodan did the scanning. You're querying their database not touching the vendor

```
$ shodan init YOUR_API_KEY          # enter once, a free account gives and API  
  
$ shodan domain scanme.nmap.org      # subdomains + DNS info  
  
$ shodan search hostname:scanme.nmap.org  # detailed host info
```

```
> TPRM-Party:~ $ shodan domain scanme.nmap.org
NMAP.ORG

A      50.116.1.184
AAAA   2600:3c01:e000:3e6::6d4e:7061
MX      alt1.aspmx.l.google.com
MX      alt2.aspmx.l.google.com
MX      aspmx.l.google.com
MX      aspmx2.googlemail.com
MX      aspmx3.googlemail.com
NS      ns1.linode.com
NS      ns2.linode.com
NS      ns3.linode.com
NS      ns4.linode.com
NS      ns5.linode.com
SOA     ns1.linode.com
TXT     google-site-verification=SrtYpJGxZzMTcczZG44XtLVK-sEPit9bputDjWc0lF4
TXT     v=spf1 a mx ptr ip4:50.116.1.184 ip6:2600:3c01::f03c:91ff:fe98:ff4e ip6:2600:3c01:e000:3e6::
6d4e:7061 include:_spf.google.com ~all
*      A      50.116.1.184
*      AAAA   2600:3c01:e000:3e6::6d4e:7061
ack     A      50.116.1.184
ack     AAAA   2600:3c01:e000:3e6::6d4e:7061
chat    A      45.33.32.156
chat    AAAA   2600:3c01::f03c:91ff:fe18:bb2f
forum   A      50.116.1.184
forum   AAAA   2600:3c01:e000:3e6::6d4e:7061
issues  A      50.116.1.184
issues  AAAA   2600:3c01:e000:3e6::6d4e:7061
research A      50.116.1.184
research AAAA   2600:3c01:e000:3e6::6d4e:7061
```

```
2600:3c01::f03c:91ff:fe18:bb2f 123 scanme.nmap.org NTP\nprotocolversion: 3\nstratum: 3\nleap: 0\nprecision: -23\nrootdelay: 0.141693115234\nrootdisp: 0.0929412841797\nrefid: 1283253834\nreftime: 3998044168.96\npoll: 3\n\n2600:3c01::f03c:91ff:fe18:bb2f 22 scanme.nmap.org SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13\nKey type: ssh-rsa\nKey: AAAAB3NzaC1yc2EAAAADAQABAAQAC6afooTZ9mVUGFNEhkMoRR1Btzu64XXwElhCsHw/zVlIx/\nHXylNbb9+11dm2VgJQ21pxkWDs+L6+EbYyDnvRURTrMTgHL0xseB0EkNqexs9hYZSiqtMx4jtGnt\nHvsMxZnbxvVUK2dasWvtBkn8J5JagSbzWTQo4hjKMOI1SULXtiKxAs2F8wiq2EdSuKw/KNk8GfIp\nn1TA+8ccGeAtnsVptTJ4D/8MhAWsROkQzOowQvnBBz2/8ecEvoMScaf+kDfNQowK3gENTSS0qYw9J\nnLOza6YJBPL/aYuQQ0nJ74Rr5vL44aNIlrGI9jJc2x0bV7BeNA5kVuXsmhyfWbbkB8yGd\nFingerprint: 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2\n\nKex Algorithms:\n\ntcurve25519-sha256@libssh.org\n\ntecdh-sha2-nistp256\n\ntecdh-sha2-nistp384\n\ntecdh-sha2-nistp521\n\ntdiffie-hellman-group-exchange-sha256\n\ntdiffie-hellman-group-exchange-sha1\n\ntdiffie-hellman-group14-sha1\n\ntdiffie-hellman-group1-sha1\n\nServer Host Key Algorithms:\n\ntssh-rsa\n\ntssh-dss\n\ntecdsa-sha2-nistp256\n\ntssh-ed25519\n\nEncryption Algorithms:\n\ntaes128-ctr\n\ntaes192-ctr\n\ntaes256-ctr\n\ntarcfour256\n\ntarcfour128\n\ntaes128-gcm@openssh.com\n\ntaes256-gcm@openssh.com\n\ntchacha20-poly1305@openssh.com\n\ntaes128-cbc\n\nt3des-cbc\n\ntblowfish-cbc\n\ntcast128-cbc\n\ntaes192-cbc\n\ntaes256-cbc\n\ntarcfour\n\ntrijndael-cbc@lysator.liu.se\n\nMAC Algorithms:\n\nthmac-md5-etm@openssh.com\n\nthmac-sha1-etm@openssh.com\n\ntumac-64-etm@openssh.com\n\ntumac-128-etm@openssh.com\n\nthmac-sha2-256-etm@openssh.com\n\nthmac-sha2-512-etm@openssh.com\n\nthmac-ripemd160-etm@openssh.com\n\nthmac-sha1-96-etm@openssh.com\n\nthmac-md5-96-etm@openssh.com\n\nthmac-md5\n\nthmac-sha1\n\ntumac-64@openssh.com\n\ntumac-128@openssh.com\n\nthmac-sha2-256\n\nthmac-sha2-512\n\nthmac-ripemd160\n\nthmac-ripemd160@openssh.com\n\nthmac-sha1-96\n\nthmac-md5-96\n\nCompression Algorithms:\n\tnone\n\ntzlib@openssh.com\n\n2600:3c01::f03c:91ff:fe18:bb2f 31337 scanme.nmap.org\n45.33.32.156 123 scanme.nmap.org NTP\nprotocolversion: 3\nstratum: 3\nleap: 0\nprecision: -23\nrootdelay: 0.136947631836\nrootdisp: 0.118225097656\nrefid: 1283253834\nreftime: 3997949099.09\npoll: 3\n\n2600:3c01::f03c:91ff:fe18:bb2f 80 scanme.nmap.org HTTP/1.1 400 Bad Request\r\nDate: Wed, 09 Sep 2026 11:19:28 GMT\r\nServer: Apache/2.4.7 (Ubuntu)\r\nContent-Length: 427\r\nConnection: close\r\nContent-Type: text/html; charset=iso-8859-1\r\n\r\n
```

The other internet-wide scanner

Different scan cadence and coverage than Shodan. Run both!

The screenshot displays the Censys web interface. On the left, a sidebar contains navigation links: Home, MY WORK, Collections, Search History, Tags, EXPLORE MODULES, Adversary Investigation, and Critical Infrastructure. A 'Free Plan' badge is visible. The main content area shows search results for 'scanme.nmap.org'. The search bar at the top right contains the text 'scanme.nmap.org'. Below the search bar, the 'Search Results' tab is active, showing a list of service labels and protocols. A red box highlights the 'SERVICE LABELS' and 'PROTOCOLS' sections. The 'SERVICE LABELS' section lists: REMOTE_ACCESS (6), LOGIN_PAGE (5), WEB_UI (4), and WEB_TECHNOLOGY (1). The 'PROTOCOLS' section lists: HTTP (19), SSH (6), DNS (2), UNKNOWN (2), and NTP (1). On the right, a 'Host Distribution' map shows the geographical distribution of the search results, with a large cluster in the United States and smaller clusters in Europe and Asia. The map includes labels for various countries and oceans. The top right of the interface shows 'RESULTS: 56' and 'DURATION: 2.43s'. A 'Personalize Results' button is also present.

Certificate Transparency – crt.sh

Every publicly trusted TLS certificate ever issued is in a public append-only log

Including those they may regret

- Certificate transparency is mandatory for browser trust, so a vendor cannot opt out of being logged
- crt.sh exposes all, including subject alternative names, which is where internal hostnames leak
- *Historical entries reveal decommissioned infrastructure and naming conventions... You can learn a lot!*

```
$ curl -s 'https://crt.sh/?q=%25.salesforce.com&output=json' | jq -r  
'[].name_value' | sed 's/^\*\./' | sort -u
```

Certificate Transparency – crt.sh

- 171 *.internal.salesforce.com results
 - *added “| grep internal | wc -l” to syntax*
- ldaps.internal.salesforce.com - directory authentication server
- ash-vpnasa.internal.salesforce.com - VPN appliance in Ashburn, Virginia
- ASH-ASA-A.internal.salesforce.com - firewall appliance in Ashburn, Virginia
- jenkins.internal.salesforce.com - CI/CD build server
- remoteapp.internal.salesforce.com - remote access gateway
- oid-stg1.internal.salesforce.com - identity management staging server
- sfm-sqlldb-wp002.internal.salesforce.com - production database server in San Francisco, California
- sfm-sqlldb-wd002.internal.salesforce.com - development database server in San Francisco, California

```
> TPRM-Party:~ $ curl -s 'https://crt.sh/?q=%25.salesforce.com' -u  
*umps40-c1-chi.salesforce.com  
*umps40-c1-was.salesforce.com  
*umps40-c2-chi.salesforce.com  
*umps40-c2-was.salesforce.com  
*umps40-c3-chi.salesforce.com  
*umps40-c3-was.salesforce.com  
1cal-wlc-a.internal.salesforce.com  
?...salesforce.com  
?...salesforce.com  
ASH-ASA-A.internal.salesforce.com  
BWONG@SALESFORCE.COM  
Developer ID Application: salesforce.com  
Ep-search.internal.salesforce.com  
Es-search.internal.salesforce.com  
Relativityweb.internal.salesforce.com  
SALESFORCE.COM CO., LTD.  
SALESFORCE.COM, INC.  
SFM0PSPOPCWP001.internal.salesforce.com  
SFM0PSPOPCWP002.internal.salesforce.com
```

DNS and Typosquat Recon

Tools: DNSDumpster, SecurityTrails, ViewDNS, and dnstwist (CLI)

- DNSDumpster gives a visual map of a domain's DNS and hosting footprint
- SecurityTrails free tier includes historical DNS, which shows infrastructure migrations and previous hosting providers
- ViewDNS provides a ton of DNS related recon options
- dnstwist checks permutations for registered typosquats and lookalikes
 - ***Registered lookalikes mean someone is already preparing to phish that vendor's customers. That customer could be you***

```
$ dnstwist --registered --format csv salesforce.com
```

Subdomain Enumeration at the CLI

Tools: subfinder, amass, and BBOT

- Every tool queries different sources, so run at least two and deduplicate
 - subfinder is fast
 - OWASP amass is thorough
 - BBOT is the modern all in one
- **Stay in passive mode!**
 - *'amass enum'* and *'subfinder'* are passive by default
 - *'amass enum -active'* may get you in trouble
 - The moment you add brute forcing, or pipe results into a scanner, you cross into the red column from the rules slide

```
$ subfinder -d salesforce.com -all -silent | httpx -silent -title -  
tech-detect -sc  
$ amass enum -d salesforce.com
```

Subdomain Enumeration at the CLI

1. Piped to 'head -n 5'
2. Piped to 'grep 200'
 - a. Live sites!

```
> TPRM-Party:~ $ go/bin/subfinder -d salesforce.com -all -silent | go/bin/httpx -silent -title -tech-detect -sc | head -n 5
https://01tower8f619f316f863c66.zzjs-074.my.commercecloud.salesforce.com [530] [Cloudflare]
https://20may2615e6a6271c912646.zzse-265.my.commercecloud.salesforce.com [530] [Cloudflare]
https://02tower73921885c0d678b8.zzjs-074.my.commercecloud.salesforce.com [530] [Cloudflare]
https://2feature123feature123feature123feature123feature123feature123feature123.bjnq-001.my.cc.salesforce.com [530] [Cloudflare]
https://264demos51cb2e82e3cf5617.zaag-009.my.cc.salesforce.com [530] [Cloudflare]

> TPRM-Party:~ $ go/bin/subfinder -d salesforce.com -all -silent | go/bin/httpx -silent -title -tech-detect -sc | grep 200 | head -n 5
https://264demosd5df02596aa92f33.blnd-dev.my.cc.salesforce.com [200] [Amazon CloudFront,Amazon Web Services,Cloudflare,Cloudflare Browser Insights]
https://123compliancesparta-8633.my.salesforce.com [200] [Login | Salesforce] [Arkose Labs,HSTS]
https://00d10000000xvw5.my.salesforce.com [200] [Login | Salesforce] [Arkose Labs,HSTS]
https://4ssecurity.my.salesforce.com [200] [Login | Salesforce] [Arkose Labs,HSTS]
https://8x8.my.salesforce.com [200] [Login | Salesforce] [Arkose Labs,HSTS]
```

urlscan.io and the Wayback Machine

What the vendor's site looked like, what it loaded, and what they have since deleted

- urlscan.io records every request a page makes: third party scripts, trackers, and embedded services
- The Wayback CDX API a machine-readable index of archived URLs, including removed pages
- Deleted status pages, old security documentation, and stale subprocessor lists are all recoverable

```
$ curl --insecure --silent  
"http://web.archive.org/cdx/search/cdx?url=*.salesforce.com/*&output=t  
ext&fl=original&collapse=urlkey" | sort -u | grep -i passw
```

Fourth Party Discovery

Your vendor's vendors the vector of recent known supply chain attacks

- Wappalyzer and BuiltWith
 - Fingerprint a vendor's technology stack from the outside, revealing platforms and services they depend on
 - The JavaScript loaded by their app tells you which analytics, support chat, payment, and CDN providers touch your data in the browser
- Cross-check all of it against the sub-processor list they give you.
 - Gaps are the finding!

Ask any vendor for a fourth party inventory and watch what happens. If they cannot produce one, they do not know who processes your data either.



4

Are They Already Compromised?

ACT IV: LEAKS & UNDERGROUND

Search Breached Accounts & Leaks

Have I Been Pwned - Troy Hunt's breach index

- Respectable, boring, and extremely useful
- <https://haveibeenpwned.com> – Use the API to check for accounts in breaches

HudsonRock – Tons of great resources

- <https://infostealers.com> – Search for accounts from info stealers
- <https://ransomware.live> – Check for previous ransomware incidents

Other great tools:

- Intelligence X, DeHashed, Leak-Lookup, RansomLook, and Ransomtracker

```
$ curl -s https://api.ransomware.live/v2/searchvictims/acme | jq -r  
'.[[]|"\"(.attackdate) \(.group) \(.victim)\"'
```

Search Breached Accounts & Leaks

```
> TPRM-Party:~ $ curl -s https://api.ransomware.live/v2/searchvictims/DentaQuest | jq -r '.[[]|"\"(.attackdate) \
(.group) \"(.victim)\"'
2026-05-30T02:05:43.541751+00:00 shinyhunters DentaQuest, LLC.
2026-05-28T07:23:38.029052+00:00 shinyhunters DentaQuest, LLC
2026-05-23T00:24:20.609136+00:00 shinyhunters DentaQuest.com
```

Don't Go to the Source!

Most leaks come from TOR, forums, and Telegram

The clear web trackers on the previous slide are derived from these sources and cover the vast majority of what a TPRM program needs

- Direct research carries risk:
 - Legal exposure
 - Malware
 - Attribution of your organization's interest
 - A policy conversation you have not had yet

Consume somebody else's collection

Know that this layer exists, know why you are choosing not to touch it

Secrets in Public Code

GitHub code search, grep.app, trufflehog, and gitleaks. Your vendor's engineers are only human.

- GitHub code search and grep.app let you search public repositories for a vendor's domain, internal hostnames, or API endpoint patterns
- trufflehog and gitleaks scan repositories and orgs for secrets, including keys committed and then deleted
 - git history keeps them!
- Scan public repos belonging to the vendor's own GitHub organization
 - It's public code, which keeps it in the green column
 - Says a lot about their secrets management maturity

```
$ trufflehog --no-update github --org=vendorname --results=verified
```

Exposed Storage and Dorking

GrayHatWarefare

- Indexes billions of files in publicly readable cloud storage buckets, searchable by keyword and filename
- <https://grayhatwarefare.com>

Google Dorks

- Get creative with your Google searches to find exposed files, secrets, etc., that have been indexed
- <https://www.exploit-db.com/google-hacking-database>
- <https://gist.github.com/sundowndev/283efaddbcf896ab405488330d1bbc06>

If you find your own organization's data in a vendor's exposed bucket, you have moved from vendor assessment to incident response

Know your escalation path in advance

30-Minute Vendor Recon Playbook

0:00	Paperwork sweep	STAR, HECVAT, trust center, FedRAMP or GovRAMP Ask for an existing CAIQ or SIG Lite
0:08	Read the evidence	SOC 2 scope, exceptions, and the CUEC list Note anything the vendor assumes you are doing
0:14	Config check	SSL Labs, securityheaders, and a DMARC check Take screenshots!
0:18	Surface mapping	crt.sh plus subfinder passive Shodan and Censys on the certificate common name
0:24	Compromise check	Have I Been Pwned domain search, Hudson Rock, and the ransomware trackers
0:28	Write it down	Short memo: what you found, what you asked, what they answered, what you accepted

But Wait! This Isn't a Full TPRM Program

Self attestation is still self attestation

- Vendor describing themselves. Verification is a separate act

Recon finds symptoms, not controls

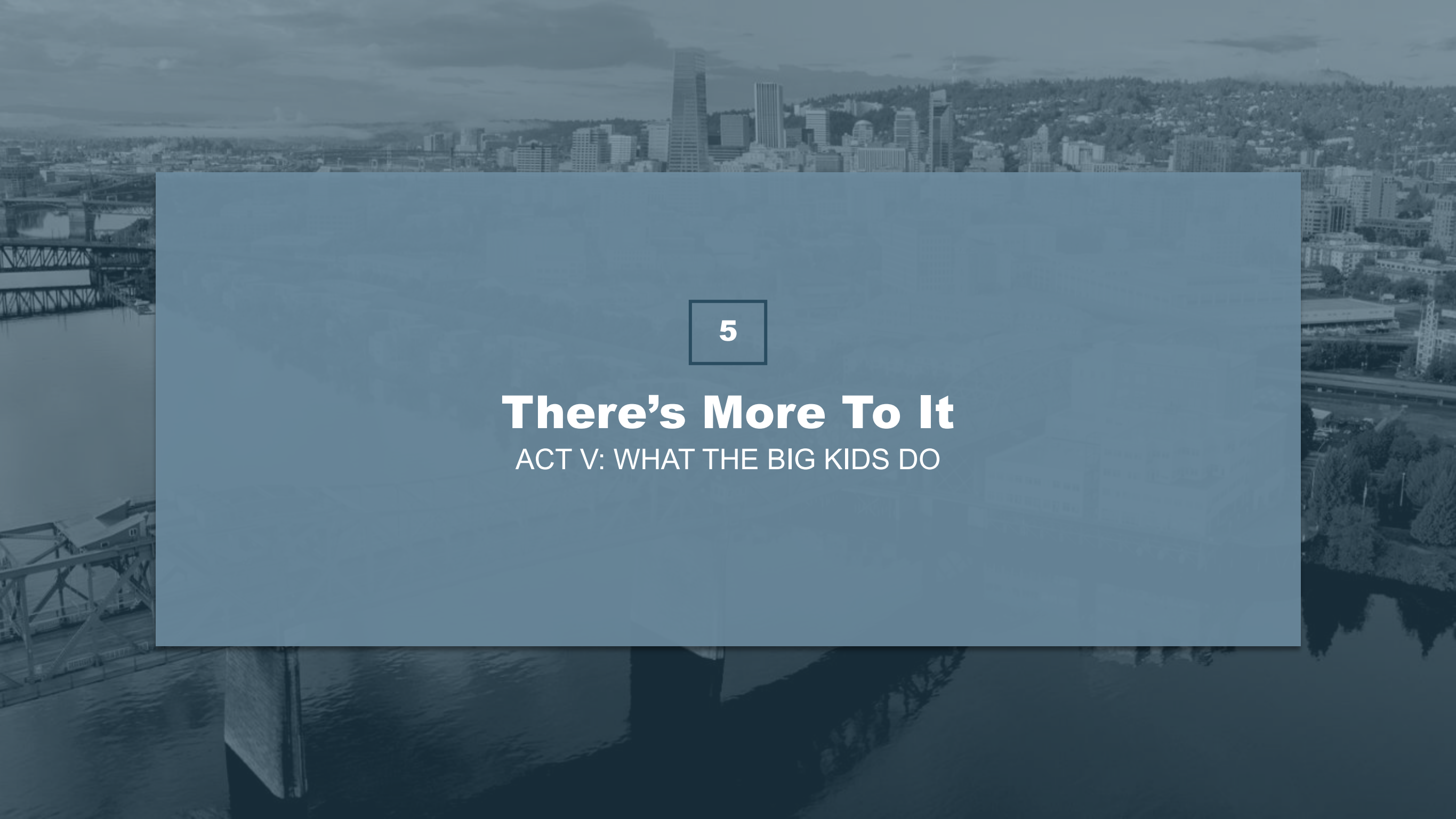
- An A grade on SSL Labs tells you nothing about their access reviews, change management, or whether anyone reads their logs

None of it is a contract

- Breach notification clocks, audit rights, subprocessor approval, and data return obligations exist only in the agreement

Not great for small vendors

- The regional vendor with twelve employees has no STAR listing, no trust center, no SOC 2

An aerial photograph of a city skyline, likely San Francisco, featuring the Transamerica Pyramid and other skyscrapers. The city is situated on a peninsula with hills in the background. In the foreground, a river flows, with a large bridge structure visible on the left side. The entire image is overlaid with a semi-transparent blue rectangle that serves as a background for the text.

5

There's More To It

ACT V: WHAT THE BIG KIDS DO

Mature Programs Align to Standards

ISO 27001:2022, A.5.19 to A.5.23

- Five Annex A controls covering supplier relationships, security in supplier agreements, ICT supply chain, monitoring and change management, and cloud services

SOC 2 Type II

- The de facto US expectation for SaaS. Type II tests operating effectiveness over a period, which is why sophisticated buyers refuse to accept a Type I

NIST CSF 2.0, GV.SC

- Ten subcategories under the new GOVERN function

The Paid Stack

Not endorsements 😊

- Dedicated TPRM platforms
 - ProcessUnity, OneTrust, etc.
- Paid tier security ratings
 - Bitsight, SecurityScorecard, etc.
- Enterprise GRC suites
 - Vanta, Drata, Archer, etc.
- Threat intel & dark web
 - Recorded Future, Zerofox, etc.
- External attack surface management
 - Censys ASM, runZero, etc.



Markers of a Mature Program

- Continuous monitoring rather than annual snapshots
- Fourth and nth party mapping
- SBOMs required from software vendors
- Exercised audit rights
- Board level reporting

Proper tooling allows:

- Scaled growth for evidence collection – dump your spreadsheets!
- Continuity through continuous monitoring
- Defensibility through automated systems of record for auditors, regulators, and/or the board

Remember!

1. Before drafting questionnaire, has someone else done the work? STAR, HECVAT, trust center
2. The government built free questionnaires, registries, and guidance. NIST, CISA, FedRAMP, and GovRAMP cost you nothing
3. The best signals need no vendor cooperation: certificate transparency, Shodan, Censys, breach and infostealer indexes, ransomware trackers
4. Passive is legal, active needs paper
 - a. Never authenticate with leaked credentials or buy stolen data!
 - b. Document your actions (CYA...)
5. Paid platforms buy coverage, defensibility, and scale. They do not buy better questions. Take what you've learned to the discussion

A black and white photograph of the Golden Gate Bridge, viewed from a low angle looking up at the tower and across the water. The bridge's suspension cables and steel structure are prominent. The water is calm, and the sky is overcast.

ARE THERE ANY QUESTIONS?



[Structured.com](https://structured.com)